Boba â€” Remaining-Work Plan (subagent-driven, path to zero-issues)

Revision: 2 **Last modified:** 2026-08-07T19:10:54Z **Status:** active **Baseline:** HEAD `7de2802` on `main` (all 4 mirrors synced). Default Python/FastAPI path is the shipped product and is essentially debt-free + fully tested; the items below are the complete, evidence-backed set of what remains for â€œnothing unfinished, zero issues.â€� **Method:** assembled from 4 parallel READ-ONLY audits (code-debt, test-health, operational/UX, security/compliance) + the Â§11.4.85 plugin-parser sweep, 2026-06-14. Every item cites real evidence (file:line / captured probe). No guessing (Â§11.4.6).

2026-08-07 re-verification note: `docs/GOVERNANCE_AUDIT_2026-08-07.md` independently re-verified every RW item against the live tree (HEAD `0d05ec1`, ~7 weeks after this plan was written) and corrected several closure claims â€” see that document (GA-11..13, GA-19..20) for full evidence. Corrections folded into the entries below rather than duplicated in a second tracker (Â§11.4.186 anti-divergence).

---

0. How to execute this plan (subagent-driven, Â§11.4.70 default)

- Each task `RW-NN` is sized for ONE subagent in an isolated context. Dispatch in the priority order below; non-contending tasks (different files) run in parallel (â‰¥3 streams, Â§11.4.103).
- **Every fix is anti-bluff (Â§11.4 / Â§11.4.107):** RED-on-broken test first (Â§11.4.115), fix at source (Â§11.4.1), GREEN with captured evidence, independent review â†’ GO (Â§11.4.142/Â§11.4.134), commit + push all mirrors. Security fixes additionally get a regression guard (Â§11.4.135) and, where they change runtime behaviour, a Â§11.4.108 runtime-signature verified on the redeployed container.
- **Acceptance = the named test passes AND the cited evidence is captured AND no regression** (full unit suite stays green). â€œDoneâ€� requires pasted real output (Â§ Definition of Done).
- Items marked **OPERATOR-DECISION** are blocked on a choice only the operator can make (threat model, scope) â€” they are surfaced via Â§11.4.66, not auto-executed.

---

1. PHASE 1 â€" Security hardening (HIGHEST PRIORITY)

The merge service exposes mutating endpoints; the operator runs it on a LAN via a `0.0.0.0` SSH tunnel, so these are reachable from any LAN host. `require_api_token` exists and is correctly written (constant-time, never logged) but is OPEN by default and only applied to the download routes.

RW-01 â€" [HIGH] Authenticate the hooks endpoint + sandbox hook execution

- **Evidence:** `download-proxy/src/api/hooks.py` has zero `require_api_token`; `POST /api/v1/hooks` registers a `script_path` executed via `subprocess.run([hook.script_path], â€¦)` (`merge_service/hooks.py:141`). Live unauth probe reached the handler (422 body-validation, not 401). A `..` guard + single-element argv exist (no shell injection), but an unauth LAN caller can register an existing in-container executable to run on event fire = code-exec.
- **Fix direction:** add `Depends(require_api_token)` to all mutating hook routes; additionally restrict `script_path` to an allowlisted directory (e.g.Â `config/hooks/`) resolved + verified at registration; reject anything outside it.
- **Acceptance:** RED test â€" unauth `POST/DELETE /api/v1/hooks` returns 401 when `BOBA_API_TOKEN` set; a hook `script_path` outside the allowlist is rejected. Regression guard added. No existing hook test regresses.
- **Discipline:** Â§11.4.1/Â§11.4.115/Â§11.4.135. **Priority: P0.**

RW-02 â€" [HIGH] Close the default-open write surface (download/upload/file + schedules + theme)

- **Evidence:** `require_api_token` (`routes.py:849-877`) returns (no auth) when `BOBA_API_TOKEN` is unset; it is unset in the running container. `scheduler.py` + `theme` routes have no token dep at all. Live unauth `POST /api/v1/download` â†' 200, torrent added.
- **Fix direction (OPERATOR-DECISION on default):** Option A â€" keep open-by-default (documented Â§11.4.122 no-auth-preservation) but make it LOUD: log a startup WARNING when `BOBA_API_TOKEN` is unset AND the bind is non-loopback. Option B â€" default-closed for non-loopback clients (derive client IP; require token unless request is from 127.0.0.1). Apply `require_api_token` consistently to schedules + theme mutations regardless.
- **Acceptance:** with `BOBA_API_TOKEN` set, all mutating routes (download/upload/file/schedules/hooks/theme) return 401 unauth + 200 with token; startup warning emitted when open + LAN-bound (captured log).
- **Discipline:** Â§11.4.66 (decision) + Â§11.4.1/Â§11.4.135. **Priority: P0.**
- **STATUS (2026-08-07): PARTIAL, not DONE.** Download/upload/file/magnet (routes.py) and POST/DELETE schedules + hooks now correctly gate on `require_api_token`, and the startup WARNING is

implemented (`api/__init__.py:84-90`). But **`PATCH /api/v1/schedules/{id}` (`scheduler.py:108`) and `PUT /api/v1/theme` (`routes.py:82`) remain unauthenticated** â€” confirmed by omission from `tests/security/test_hooks_schedules_auth.py:194-198`â€™s own `_MUTATING` enumeration, which never included them. See `docs/GOVERNANCE_AUDIT_2026-08-07.md` GA-11 for the remediation task.

RW-03 â€” [MED-HIGH] Block SSRF in server-side URL fetch

- **Evidence:** `download_torrent_file` non-tracker branch + the `/download` flow do `aiohttp...get(<user download_urls entry>)` with no host validation (`routes.py:1170-1187`). A caller can make the proxy fetch `http://169.254.169.254/â€¦`, `http://localhost:7185/â€¦`, or LAN hosts and receive the body.
- **Fix direction:** after DNS resolution, reject RFC-1918 / loopback / link-local / metadata (169.254.169.254) / multicast targets; or restrict to known tracker hosts. Apply to BOTH the `/download/file` and `/download` non-tracker fetch paths.
- **Acceptance:** RED test â€” a `download_urls` entry pointing at a private/loopback/metadata IP is rejected (no fetch); a legit tracker URL still works. Regression guard.
- **Discipline:** Â§11.4.1/Â§11.4.115/Â§11.4.135. **Priority: P0.**

RW-04 â€” [MED] Auth-consistency + Go-proxy CORS + Jackett admin

- **Evidence:** `generate_magnet` (`routes.py:1195`) lacks `require_api_token` (siblings have it). Go Gin proxy `middleware.CORS("*")` + `Allow-Credentials:true` (`cmd/qbittorrent-proxy/main.go:45`, `internal/middleware/cors.go:11-14`) â€” forbidden wildcard+credentials combo (opt-in Go profile only). Jackett `:9117` has `AdminPassword_set=False`, LAN-exposed.
- **Fix direction:** add token dep to `/magnet`; fix Go CORS to echo an allowlisted Origin (mirror the hardened `jackettapi/cors_middleware.go`); set a Jackett admin password (or document the localhost-only assumption + the `0.0.0.0` exception).
- **Acceptance:** `/magnet` 401 unauth (token set); Go CORS no longer returns *+credentials (Go test); Jackett admin requires a password OR a documented operator decision.
- **Discipline:** Â§11.4.1 + Â§11.4.66. **Priority: P1.**

RW-05 â€” [MED] OPERATOR-DECISION â€” LAN-exposure threat model

- **Evidence:** the tunnel binds `0.0.0.0` (`TUNNEL_BIND_ADDR=0.0.0.0`), exposing 7186/7187/7189/9117 to the LAN; several mutating endpoints + the Jackett admin are open.

- **Decision needed:** is LAN access required, or should the tunnel bind `127.0.0.1`? If LAN is required, RW-01..04 + a Jackett password are mandatory; if not, binding loopback closes most of the surface at once.
- **Discipline:** Â§11.4.66. **Priority: P1 (gates how aggressive RW-02 must be).**

---

2. PHASE 2 â€” Functional correctness + deployment

RW-06 â€” [MED] Deploy the rutracker ReDoS fix to the running container (Â§11.4.108)

- **Evidence:** the ReDoS fix landed in source (`plugins/rutracker.py`, HEAD 7de2802) but the running container uses the installed copy (`config/qBittorrent/nova3/engines/rutracker.py`). Until `install-plugin.sh` + proxy restart, live searches still use the vulnerable regex.
- **Fix:** `./install-plugin.sh` (copies pluginsâ†’engines), clear `__pycache__`, `podman restart qbittorrent-proxy`; re-establish tunnel (self-healer handles it). Verify Â§11.4.108 runtime-signature: the installed engine file contains `{0,512}` and a live large-result rutracker search returns < 2s parse.
- **Acceptance:** `grep '0,512' config/qBittorrent/nova3/engines/rutracker.py` present on the container; captured timing of a large rutracker result page < 2s.
- **Discipline:** Â§11.4.108. **Priority: P1.**
- **STATUS (2026-08-07): UNVERIFIABLE, not DONE.** Source fix confirmed present (`plugins/rutracker.py:140`). No live container stack was running on the audit host â€” the deployed-artifact/runtime layers remain unconfirmed. See GA-12.

RW-07 â€” [MED] nnmclub `/auth/nnmclub/status` SOURCEâ†’ARTIFACT drift

- **Evidence:** route exists in `download-proxy/src/api/auth.py` (BOB-006) but returns 404 on the running container; `tests/e2e/test_live_stack_evidence.py:265` skips because of it.
- **Fix:** redeploy the proxy so source == artifact; confirm the route returns 200 live; the e2e test then asserts for real (un-skips).
- **Acceptance:** `curl :7187/api/v1/auth/nnmclub/status` â†’ 200; the e2e no longer skips. (Likely resolved together with RW-06â€™s restart â€” verify.)
- **Discipline:** Â§11.4.108/Â§11.4.139. **Priority: P1.**
- **STATUS (2026-08-07): PARTIAL/UNVERIFIABLE, not DONE.** Route exists in source (`download-proxy/src/api/auth.py:350`) but `tests/e2e/test_live_stack_evidence.py:265` still contains the SKIP-on-404 fallback â€” it was never removed, so the acceptance criterion is unmet regardless of live container state. See GA-13.

RW-08 â€” [MED] Search latency + `/search/sync` reset over tunnel

- **Evidence:** broad `ubuntu` search = ~67s in-container; over the tunnel `/search/sync` resets (`ConnectionResetError`) at ~13â€“40s. SSE path (`/search` + `/search/stream/{id}`) survives via 15s keepalives; the dashboard uses it. Scripted/curl callers of `/search/sync` hang.
- **Fix direction:** (a) tune per-plugin deadlines (`PUBLIC_TRACKER_DEADLINE_SECONDS`) to cut latency; (b) document/steer non-browser callers to the streaming endpoint; optionally add a keepalive/heartbeat to the sync path. Add a Â§11.4.85 chaos test for the sync-over-slow-link timeout behaviour.
- **Acceptance:** documented guidance + (if tuned) a measured latency reduction with captured before/after; SSE path confirmed robust.
- **Discipline:** Â§11.4.6/Â§11.4.85. **Priority: P2.**

---

3. PHASE 3 â€” Go backend parity (only if the Go profile is to become viable)

`docs/migration/PARITY_GAPS.md` (Rev 1): 6 ported / 4 partial / **8 missing** of 18 features. The Go backend is opt-in (`--profile go`) and NOT running; the Python path is complete. Switching profiles today regresses. **OPERATOR-DECISION (RW-09): is Go parity a goal for this release, or is the Go backend a future blueprint?** If yes, file each gap as a ticket and execute; if no, mark them deferred-by-design and move on.

STATUS (2026-08-07): still unresolved. `docs/migration/PARITY_GAPS.md` and `docs/features/Status.md:52,194` are unrevised since 2026-04-27. Confirmed still fully absent: scheduler ticker/driver loop (RW-10 â€” â€œhighest-impact silent functional holeâ€�), enricher equivalent (RW-11), plugin fan-out (RW-12). RW-13 has moved to PARTIAL (Jackett autoconfig is now its own canonical Go service) but BEP48/scrape validation + a CAPTCHA REST endpoint are still missing. See GA-19 â€” this decision blocks real scope commitment and should be made before any RW-10..13 work starts.

- **RW-10** [Go] Scheduler driver loop â€” MISSING (verified): `scheduler_api.go` stores List/Create/Delete but has no ticker â†’ Go-path schedules never fire. (Highest-impact silent functional hole on the Go path.)
- **RW-11** [Go] Metadata enricher (no Go equiv of `enricher.py`) â€” search loses posters/year/type.
- **RW-12** [Go] Public-tracker plugin fan-out (the ~42 Python plugins are unreachable via Go).
- **RW-13** [Go] Tracker validator (BEP 48/15 scrape), private-tracker auth/CAPTCHA REST, Jackett auto-config, shared retry policy, Jinja2 fallback dashboard, `/api/v1/jackett/autoconfig/last`.

- **Acceptance per task:** Go REDâ†'GREEN test (`go test -race`), parity feature reachable on `--profile go`, PARITY_GAPS.md row flipped to Ported. **Priority: P3 (gated on RW-09).**

---

4. PHASE 4 â€" Coverage completion (Â§11.4.85 / Â§11.4.27)

Â§11.4.85 stress/chaos now covers: button endpoints (Py+Go), dedup, search-orchestration/SSE, bridge, auth, enricher, Go magnet handler, plugin parsers. **Remaining surfaces lacking stress/chaos** (each a P2 task, parallelizable, offline-mockable): - **RW-14** download-proxy tracker-fetch + cookie-auth path (the proxy that intercepts tracker URLs) â€" also overlaps the RW-03 SSRF surface. - **RW-15** scheduler driver + hooks dispatch + SSE broker (Python side). - **RW-16** boba-jackett (Go) autoconfig path + the encrypted SQLite DB ops. - **RW-17** [verify, from test-health audit] confirm the full coverage map + that every CM-* gate referenced in CLAUDE.md is actually enforced by a pre-build script (not documented-only); file any documented-but-unimplemented gate as a task. *(This section to be refined with the test-health auditâ€™s coverage % + gate-enforcement findings when they land.)* - **Acceptance per task:** new `tests/stress/test_*_stress_chaos.py`, negation-proven, captured evidence, both deterministic + randomized. **Priority: P2.** - **STATUS (2026-08-07):** RW-14 and RW-15 are **still NOT-DONE** â€" commit `a410b91` (â€œclose Go + extension coverage gaps RW-14/RW-16â€�) actually added Go `internal/jackett/internal/logging` unit tests and an extension parser test, NOT Â§11.4.85-conformant stress/chaos coverage for the tracker-fetch/cookie-auth path or the scheduler+hooks+SSE-broker surface; no matching test files exist. **The commitâ€™s original RW-14/RW-15 closure claim was inaccurate** (Â§11.4.6 â€" recorded here rather than left standing). RW-16 is PARTIAL: `qBitTorrent-go/tests/integration/jackett_db_test.go:440-500` has a genuine 50-goroutine concurrent-write test, but it predates this plan (commit `8936545`, 2026-04-27) and has no chaos-style fault injection. RW-17 sample audit (7 CM-* gates checked): only 2 (`CM-REPORTING-DIRECTIVES`, `CM-TRACK-BRANCH-LABEL`) have real implementing scripts; 5 (`CM-STATUS-CUSTODY`, `CM-GUARD-ASSERTS-REAL-CONDITION`, `CM-EXHAUSTIVE-REVIEW-ALL-SCENARIOS`, `CM-DEAD-CODE-INVESTIGATE-BEFORE-REMOVE`, `CM-SUMMARY-CLARITY-DESCRIPTIONS`) are documented-only â€" consistent with the constitutionâ€™s own Â§11.4.227 admission that ~58% of named gates are unimplemented at the constitution-submodule layer; not a boba-specific defect to fix locally. See GA-20 in `docs/GOVERNANCE_AUDIT_2026-08-07.md` for the remediation task.

---

5. PHASE 5 â€" Docs, release readiness, housekeeping

- **RW-18** [LOW] Â§11.4.65 export the 10 `courses/0{1..4}-*/{README,script}.md` operator docs (`scripts/

`generate_markdown_exports.sh`). (Canonical `docs/` tree is already clean.)

- **RW-19** [LOW] Fix stale `docs/browser_extension/RELEASE_READINESS.md` locale claim (it says 4 locales; all 8 are committed) + reconcile the live-7187 round-trip status (CONTINUATION says GREEN, RELEASE_READINESS lists it open).
- **RW-20** [LOW] Create a top-level Boba (proxy/merge-service) v1.0.0 readiness ledger (only the extension has one) before promoting `v1.0.0-rc` â†’ `1.0.0`.
- **RW-21** [INFO] Ensure contract tests (`tests/contract/test_openapi_frozen_in_sync.py`) run green under Python 3.12 (the new magnet/download endpoints are already in the frozen `docs/api/openapi.json` â€” no drift, just confirm under the right interpreter).

---

6. Operator-blocked / decisions (surfaced, not auto-executed)

Item	Why blocked	What we need
BOB-008 RuTracker automated login	CAPTCHA is an irreducible human step	Operator solves CAPTCHA at `/api/v1/auth/rutracker/captcha`+`/login` OR pastes a fresh `bb_session` cookie. Runbook: `docs/qa/BOB-008/operator_runbook.md`. Every surrounding mechanism is tested.
RW-05 LAN threat model	Only operator knows the deployment	Bind tunnel `127.0.0.1` vs keep `0.0.0.0`+auth (drives RW-02 aggressiveness).
RW-09 Go parity goal	Scope decision	Is `--profile go` a release goal or a future blueprint?
â€œJackett auto-login like qBitâ€�	Ambiguous ask	Jackett currently needs no login only because its admin password is unset; there is no auto-login parity with qBitâ€™s `POST /api/v1/auth/qbittorrent`. Confirm whether parity UX is wanted (then itâ€™s a new feature task) or â€œno login

Item	Why blocked	What we need
		neededâ€� already satisfies it.
Extension Phases 4â€“9 (live-7187 E2E, Phase-5 wiring, Phase-9 packaging, store assets)	Operator-gated (shared `/Volumes/T7` into VM, real display, store media)	Out of scope for the proxy/merge-service product; tracked in the extensionâ€™s own RELEASE_READINESS.

7. Suggested execution order (zero-issues path)

1. **P0 security first, in parallel:** RW-01 (hooks code-exec), RW-02 (default-open writes), RW-03 (SSRF) â€” these are the real exposure. Get RW-05 decision early as it shapes RW-02.
2. **P1 deploy + consistency:** RW-04, RW-06 (deploy ReDoS fix), RW-07 (nnmclub drift).
3. **P2 coverage + ops:** RW-08, RW-14..17.
4. **P3 (if RW-09=yes):** RW-10..13 Go parity.
5. **P5 docs/release:** RW-18..21, then the v1.0.0 readiness gate (Â§11.4.40 full retest) before any tag.

Definition of â€œfinally finished, zero issuesâ€�: all P0/P1 closed with regression guards + redeployed + Â§11.4.108-verified live; P2 coverage gaps closed; operator decisions (RW-05/09 + Jackett clarification) resolved; the v1.0.0 readiness ledger green; the full Â§11.4.40 retest passes; everything pushed to all mirrors.